Berner Fachhochschule
Haute école spécialisée bernoise
Bern University of Applied Sciences



IAM

Self-Sovereign Identity (SSI) – Konzept und Umsetzung

Prof. Dr. Annett Laube, HS 2026, HSLU

2017 - Die Vision



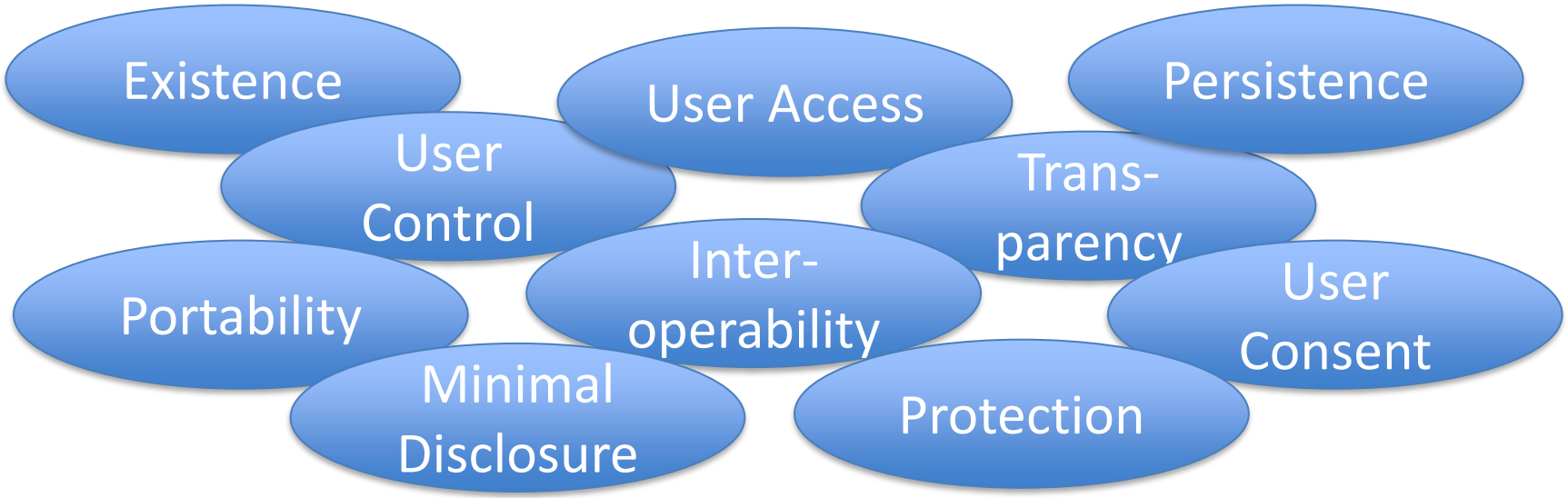
'Self-Sovereign Identity is the next step beyond user-centric identity and that means it begins at the same place: the user must be central to the administration of identity.'

— **Christopher Allen**

- https://github.com/ChristopherA/self-sovereign-identity/blob/master/ThePathToSelf-SovereignIdentity.md

Self-Sovereign Identität

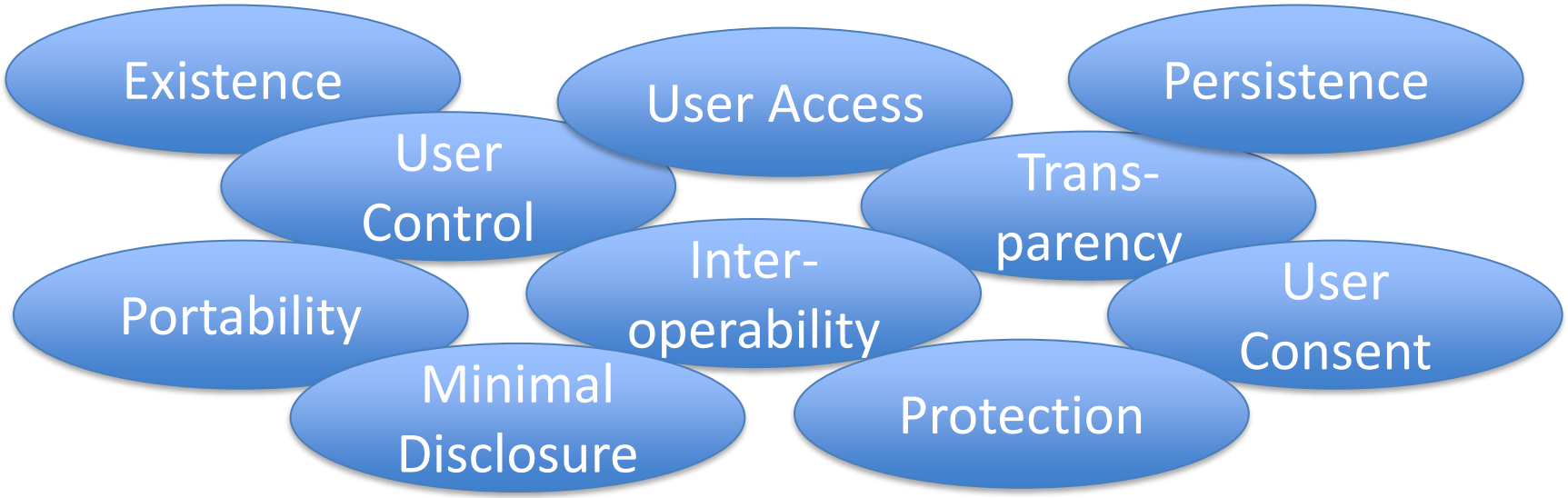
- Der Benutzer ist Eigentümer seiner elektronischen Identität und damit im Besitz seiner persönlichen Daten (und niemals ein zentraler Dienst oder ein staatlicher Herausgeber).
- Es gibt keine zentrale Ablage von Identitätsdaten, sondern nur Bestätigungen in öffentlichen, dezentralen Registern.



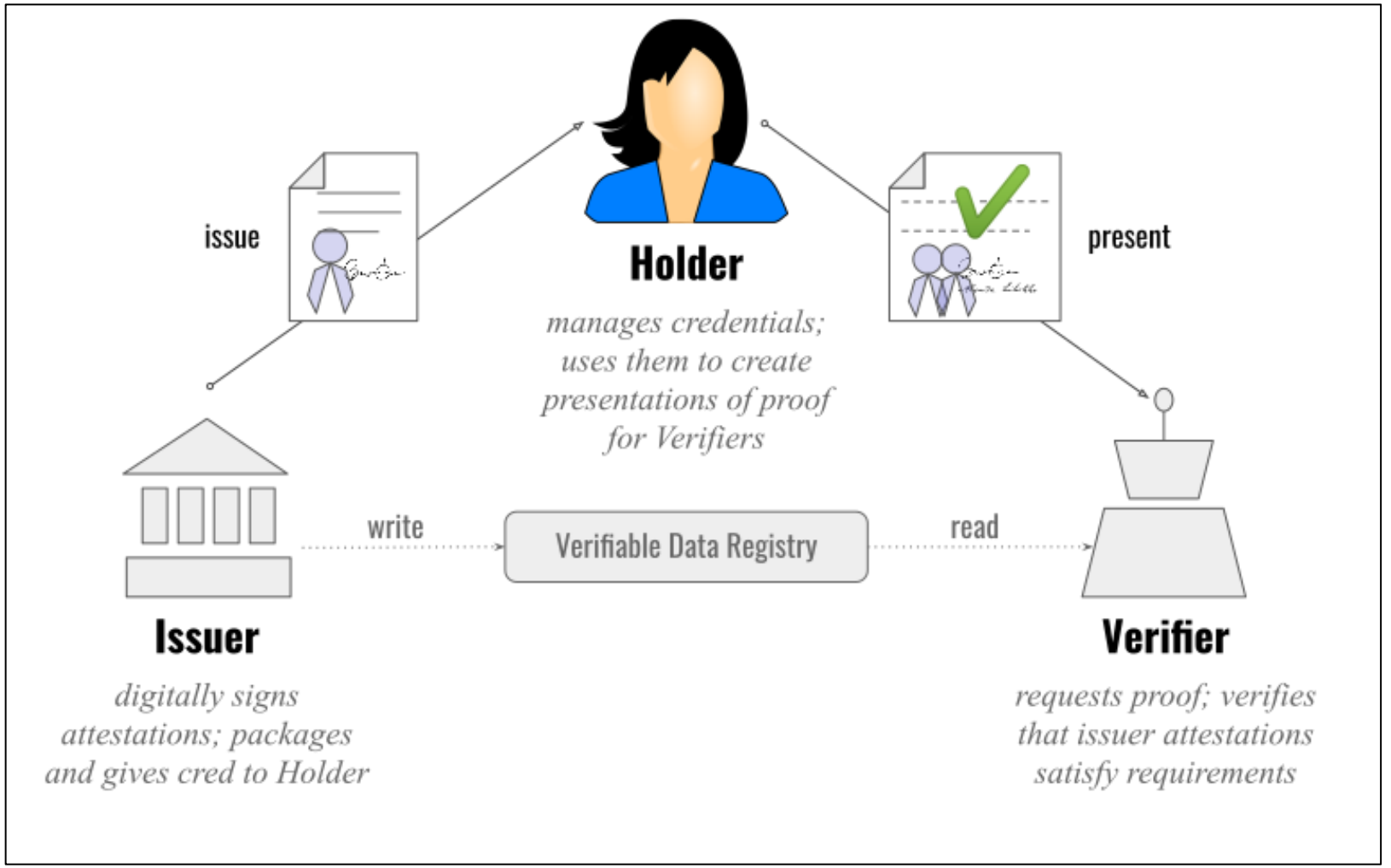
Die 10 Prinzipien von SSI

SSI Heute

SSI bezieht sich auf einen **dezentralen** Ansatz, bei dem Personen nicht auf einen Drittanbieter angewiesen sind. Sie können ihre Identitätsdaten mithilfe kryptografischer Verfahren sicher auf ihrem **Smartphone** speichern. Ausserdem können sie persönliche Daten **selektiv** an vertrauenswürdige Einrichtungen oder Dienstleister **weitergeben**.



Rollen bei SSI



Rollen bei SSI

1. Issuer (Aussteller)

Der Issuer stellt eine vertrauenswürdige Entität dar, welche digitale Nachweise, sog. *Verifiable Credentials (VC)*, erstellt und ausgibt. Diese Nachweise können verschiedene Informationen enthalten, wie zum Beispiel persönliche Daten des Holders, Qualifikationen oder Mitgliedschaften.

Der Issuer stellt sicher, dass die ausgestellten Nachweise der Realität entsprechen und überprüfbar sind.

2. Holder (Inhaber)

Der Holder ist die Person oder Entität, welcher die Nachweise an einem dezentralen, vom ihm kontrollierten Speicherort («Wallet») speichert.

Der Holder hat die volle Kontrolle über seine Nachweise und kann sie mit Hilfe seines Wallets idealerweise datensparsam an Verifier weitergeben, je nach Bedarf und Zustimmung.

Rollen bei SSI

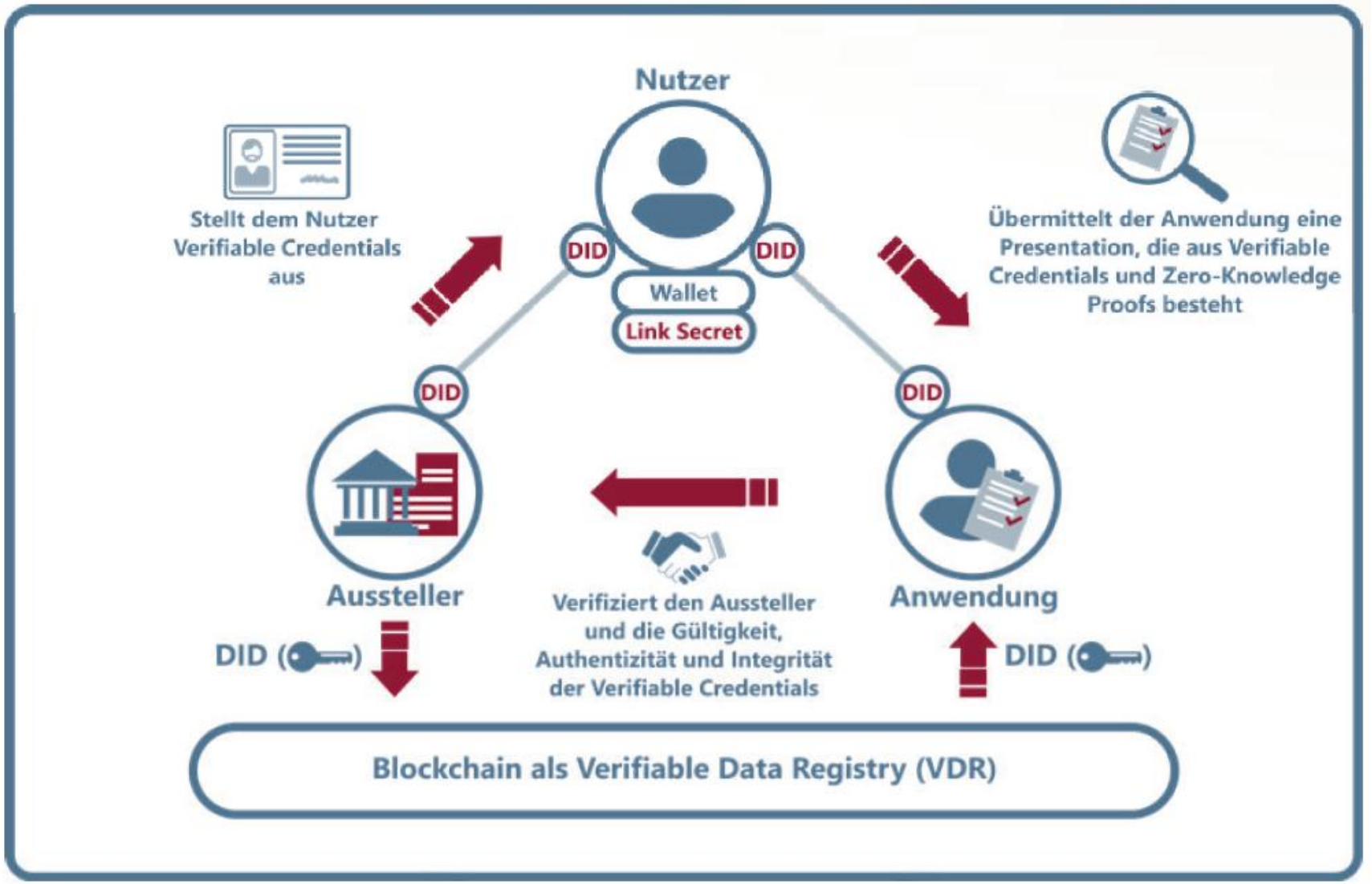
3. Verifier (Prüfer)

Der Verifier ist eine Entität, welche die Nachweise des Holders überprüfen möchte.

Er stellt somit eine Anfrage an den Holder, welcher bestimmte Nachweise vorlegen soll. Der Holder kann dann diese Nachweise in abgewandelter Form, als *Verifiable Presentations (VP),* idealerweise sicher und datensparsam dem Verifier präsentieren.

Der Verifier kann die Integrität und Authentizität der VPs prüfen.

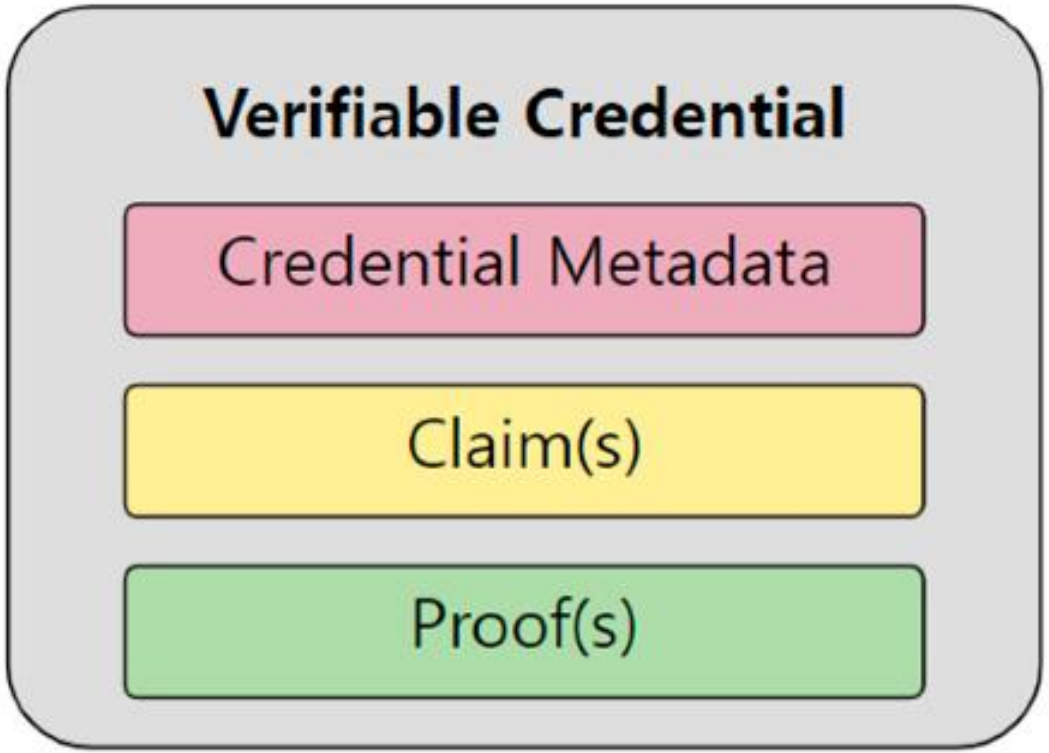
Protokolle


Nutzer
Stellt dem Nutzer Verifiable Credentials aus
DID
DID
Wallet
Link Secret
Übermittelt der Anwendung eine Presentation, die aus Verifiable Credentials und Zero-Knowledge Proofs besteht
DID
DID
Aussteller
Verifiziert den Aussteller und die Gültigkeit, Authentizität und Integrität der Verifiable Credentials
Anwendung
DID ( )
DID ( )
Blockchain als Verifiable Data Registry (VDR)

Verifiable Credentials

Ein *Verifiable Credential* (digitaler Nachweis) enthält ein oder mehrere *Claims*, d.h. bestätigte Attribute zu einem Subjekt. VC können einen *Identifikator* haben und *Metadaten*, z.B. Informationen zur Ausstellung und Gültigkeit, enthalten.

Ein Proof ist eine Signatur der Claims durch den Issuer. Ein VC kann mehrere *Proofs*, sog. *Proof Sets*, ggf. basierend auf unterschiedlichen Signaturverfahren, enthalten.

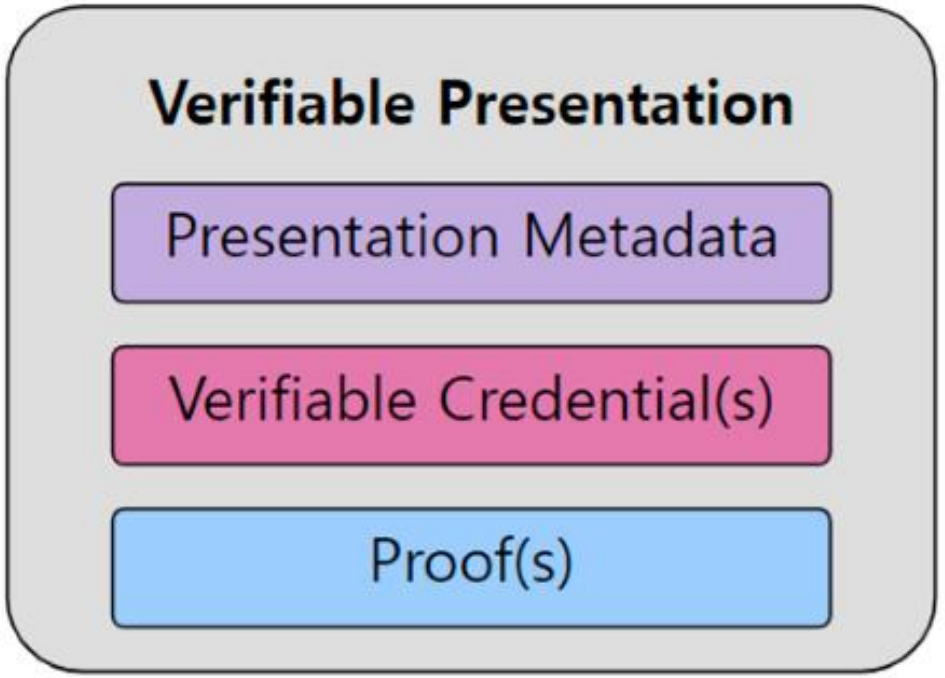


Mehr: https://www.w3.org/TR/vc-overview/

Verifiable Presentations

Eine Verifiable Presentation wird vom Holder erstellt und kann ein oder mehrere VCs von einem oder auch mehreren Issuern enthalten.

Ein VP enthält Presentation Metadaten, die die Struktur der eingebetteten VCs beschreiben und (optional) Proofs, d.h. Signaturen.



Selective Disclosure (Selektive Offenlegung)

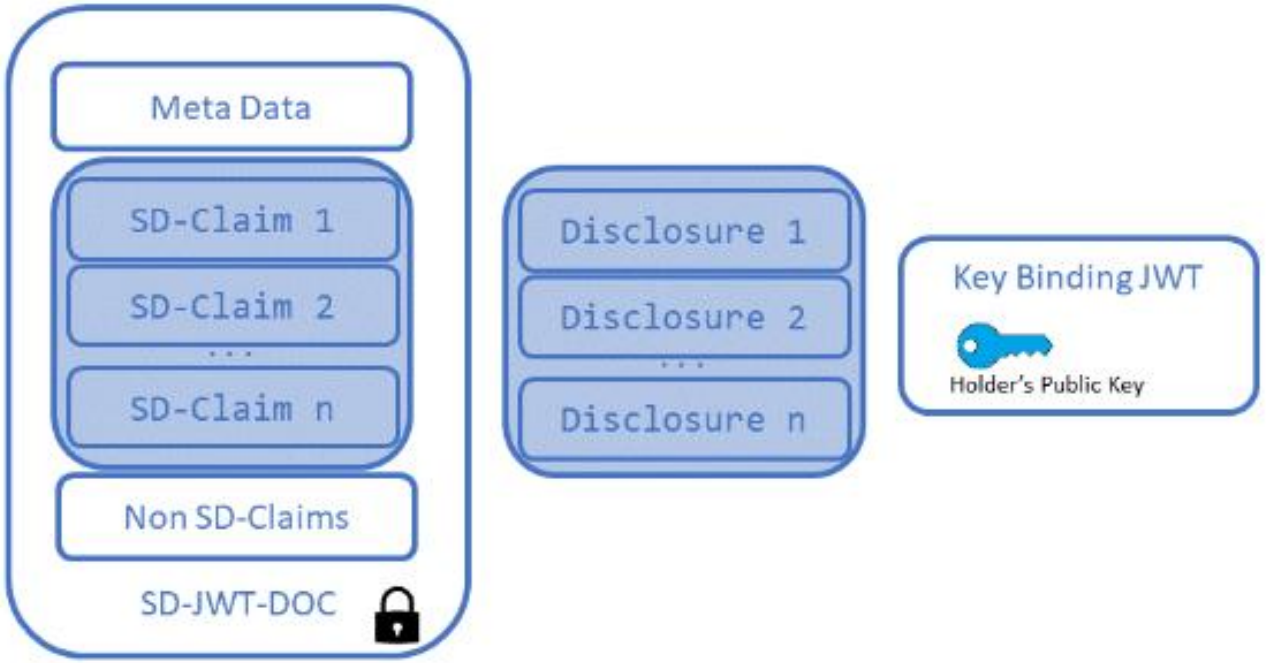
- *Selective Disclosure* ist ein Verfahren, das es dem Besitzer (Holder) der von einem Issuer signierten Daten erlaubt, nur einen Teil der signierten Daten offenzulegen. Die Schwierigkeit dabei ist, dass der Empfänger (Verifier) in der Lage sein muss, die Integrität und Authentizität der offengelegten Daten zu überprüfen.
- *Selective Disclosure* ist eine wichtige Funktionalität, um möglichst nur die minimal geforderten Daten offenzulegen und so die Privatsphäre des Besitzers zu schützen.
  - **Achtung**: Es können nur als optional oder nicht angeforderte Daten aus einem VC versteckt werden.

Selective Disclosure

- Lösungsansätze:
  - **Atomare Attribute**: Attribute werden einzeln vom Issuer signiert und dann zu VC zusammengesetzt (es gibt keine Garantie, dass die Attribute zusammengehören)
  - **SD-JWT**: mit Hilfe klassischer Signaturen kann ein Teil der Daten verborgen werden.
  - **Multi-Message-Signaturverfahren** unterstützen inhärent Selektive Disclosure

Selective Disclosure for JWTs (SD-JWT)

- ermöglicht es nur einen Teil der Daten eines signierten JWTs offenzulegen.
- statt der üblichen Claims (Key-Value-Paare) werden SD-CLAIMs (Hash-Werten der Key-Value-Paare), eingebettet.
- Zusammen mit dem signierten SD-JWT erhält der Holder eine Liste mit sog. Disclosures mit den Key-Value-Paaren im Klartext
- Bei einer Präsentation des JWTs kann der Holder entscheiden, welche Disclosures er dem Verifier vorlegt. Der Verifier kann die Unveränderthеit der Disclosures mit Hilfe der signierten Hash-Werten aus dem SD-JWT prüfen.



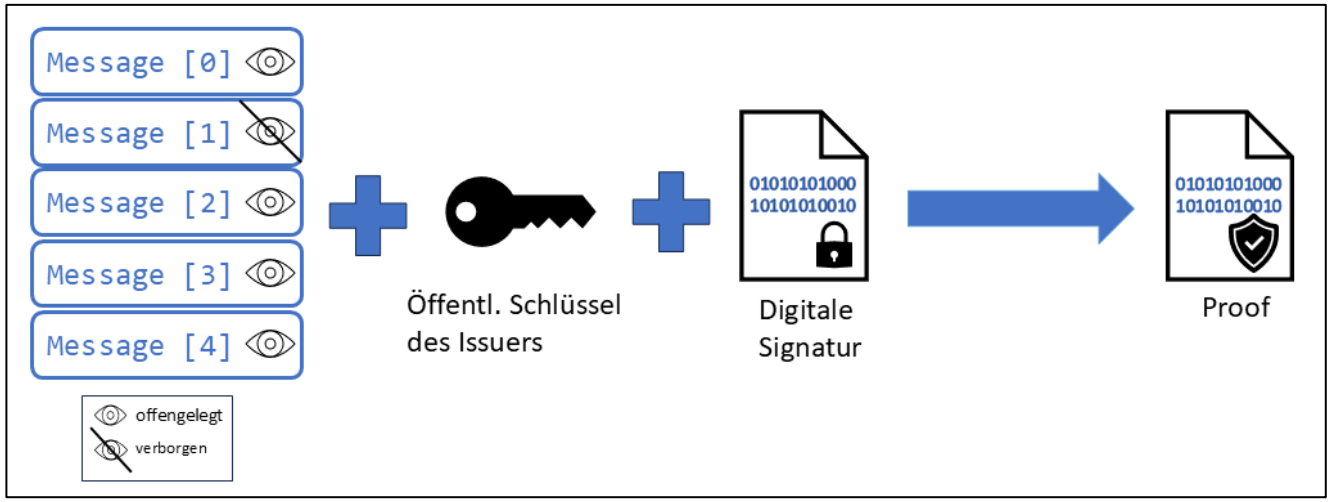
optional Mechanismus für Key Binding: ein SD-JWT wird an den öffentlichen Schlüssel des Holders gebunden, so dass der Holder den Besitz des entsprechenden privaten Schlüssels bei einer Präsentation nachweisen muss.

Multi-Message-Signaturverfahren

Multi-Message-Signaturen verwenden *Zero-Knowledge Proofs (ZKP),* d.h. kryptographische Beweise, mit dem man beweisen kann, dass eine bestimmte Aussage wahr ist, ohne dem Überprüfer mehr Informationen zukommen zu lassen. Dadurch sind Proofs nicht linkbar (sog. *unlinkbare Proofs)*.

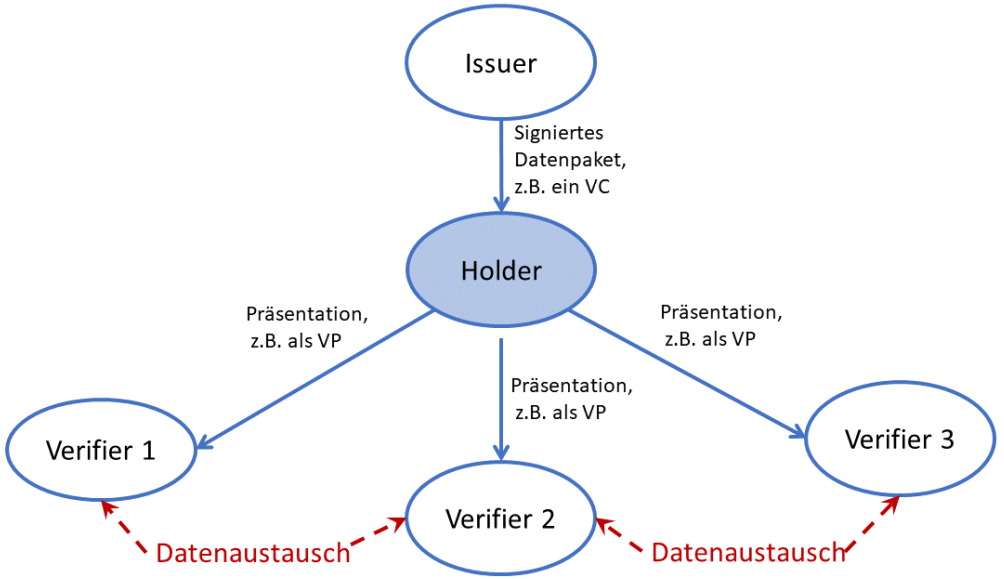
In Bezug auf digitale Signaturen möchte der Holder (Besitzer der Signatur) beweisen, dass er für ein bestimmtes Datenpaket eine von einem Issuer ausgestellte Signatur besitzt, ohne diese Signatur vorzuweisen.

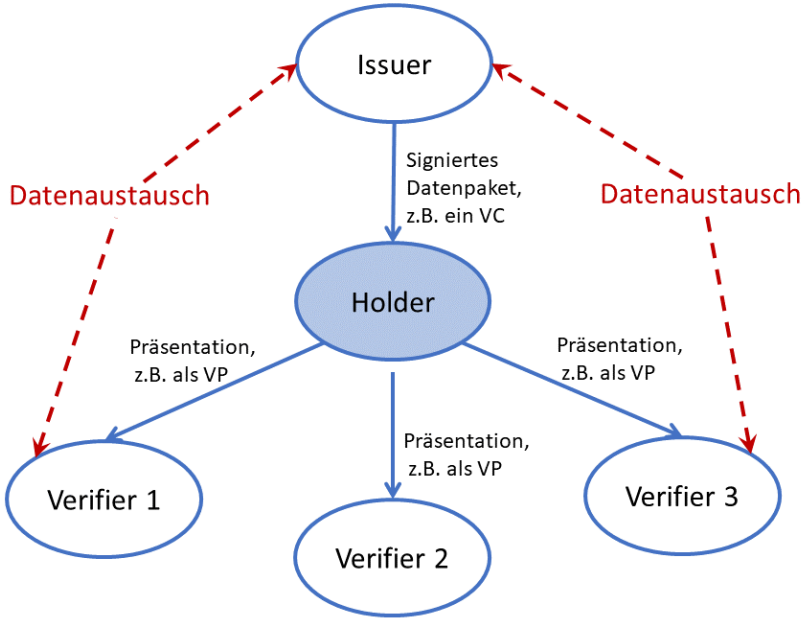
Bei der Erzeugung des Proofs ist ausserdem eine selektive Offenlegung möglich, d.h. man kann die Nachrichten auswählen, die man verstecken bzw. offenlegen möchte



Verlinkbarkeit

Eindeutige Werte (beispielsweise die Signatur) aus VC und VPs können von verschiedenen Issuern und Verifiern korreliert werden und zur Erstellung und Kopplung von Benutzerprofilen verwendet werden.





Unverlinkbarkeit kann nur mit modernen Multi-Message-Signaturverfahren, wie BBS erreicht werden. Aber auch da muss zusätzlich auf Unverlinkbarkeit der Metadaten etc. geachtet werden.

Holder Binding (Inhaberbindung)

- *Holder Binding* ist ein Prozess, mit dem nachgewiesen wird, dass ein VC für einen bestimmten Holder ausgestellt wurde. Dazu beweist der Holder gegenüber dem Issuer und gegenüber dem Verifier, dass er über ein Geheimnis verfügt (z.B. ein privater Schlüssel oder ein geheimer Wert). Der Issuer verankert das Geheimnis direkt oder indirekt im VC, so dass der Verifier dies überprüfen kann.
- In der Praxis wird die Inhaberbindung häufig mit einer **Gerätebindung** kombiniert.

Gerätebinding (device binding)

- Gerätebindung stellt sicher, dass ein VC eindeutig an ein bestimmtes Gerät (Entität) gebunden wird und sich nicht auf ein anderes Gerät übertragen lässt.
- Im Gegensatz zur Inhaberbindung garantiert die Gerätebindung dabei nicht, dass das Subjekt auch der Inhaber bzw. die Inhaberin (Holder) der dezentralen Identität oder des VC ist.

Vor- und Nachteile von digitalen Nachweisen



- Benutzer erhält mehr Kontrolle über seine digitalen Nachweise und deren Verwendung
- dezentrale Speicherung der Benutzerdaten
  - eIDAS und DSGVO konform
- Weniger Abhängigkeit von Identitätslieferanten bei der Verwendung
- Ggf. Sicherheit, Privacy, Transparenz



- Können nicht ohne Weiteres zur Authentifizierung verwendet werden
- Hohe Komplexität/neue Technologien
  - Alle RA/RP müssen angepasst werden
  - Implementierungsaufwand/Kosten ?
- Benutzer hat mehr Verantwortung
  - Keine zentrale Anlaufstelle bei Problemen, z.B. bei verlorenen Nachweisen
- Auf unsicherer Plattform (Smartphone)
- Etablierung des Vertrauens & Governance